

Technical report

Evidence-led findings. Transparent coverage.

RUN	037408c78db44255
NETWORK MODE	offline
STATE	COMPLETED_WITH_LIMITATIONS
CANDIDATE FINDINGS	5
GENERATED	2026-09-22T03:57:31.849778+00:00

Assessment boundaries

Findings require manual validation; no compliance certification or complete vulnerability detection.

Browser execution, state-changing active attacks, business-logic verification and authenticated role comparisons are not supported.

Dependency matching is limited by supplied snapshots and inventory coverage; missing data remains NOT TESTED.

Framework mappings are a reviewed subset of related evidence, not complete ASVS/NIST/ATT&CK control assessments.

Source rules are syntax/regex heuristics; external scanners require a working isolated execution profile.

AI usage

Enabled: False; provider: none; verification: not used

Coverage

source - PARTIAL

Bounded heuristic checks executed; manual validation required. Inventory records processed files.

secrets - PARTIAL

Bounded heuristic checks executed; manual validation required. Inventory records processed files.

config - PARTIAL

Bounded heuristic checks executed; manual validation required. Inventory records processed files.

dependencies - NOT TESTED

DATA_MISSING: advisory snapshot absent

openapi - PARTIAL

Bounded heuristic checks executed; manual validation required. Inventory records processed files.

Execution notes

dependency database: DATA_MISSING

Technical findings

1. Dynamic code execution requires review

HIGH / MEDIUM / NEEDS MANUAL REVIEW

Asset: app.py:6

Dynamic execution can interpret untrusted input. This is a syntax-based candidate, not data-flow proof.

Evidence: app.py:6: pattern matched; source content omitted

Remediation: Remove dynamic evaluation or strictly validate trusted input.

Retest: Apply remediation and repeat this check; manually verify the affected workflow.

Related evidence: NIST CSF 2.0 / ID.RA-01

2. Shell subprocess requires review

HIGH / MEDIUM / NEEDS MANUAL REVIEW

Asset: app.py:8

shell=True enables shell interpretation.

Evidence: app.py:8: pattern matched; source content omitted

Remediation: Use an argument list with shell=False.

Retest: Apply remediation and repeat this check; manually verify the affected workflow.

Related evidence: NIST CSF 2.0 / ID.RA-01

3. Debug mode enabled

MEDIUM / MEDIUM / NEEDS MANUAL REVIEW

Asset: app.py:3

Debug setting is enabled.

Evidence: app.py:3: pattern matched; source content omitted

Remediation: Disable debug mode in production.

Retest: Apply remediation and repeat this check; manually verify the affected workflow.

Related evidence: NIST CSF 2.0 / ID.RA-01

4. Potential hardcoded credential

HIGH / MEDIUM / NEEDS MANUAL REVIEW

Asset: app.py:4

A credential-like assignment contains a literal. Value intentionally discarded.

Evidence: app.py:4: pattern matched; source content omitted

Remediation: Review whether the value is sensitive; rotate exposed credentials and use a secret store.

Retest: Apply remediation and repeat this check; manually verify the affected workflow.

Related evidence: NIST CSF 2.0 / ID.RA-01

5. API operation has no declared security

MEDIUM / MEDIUM / NEEDS MANUAL REVIEW

Asset: openapi.json:1

GET /public has no non-empty security requirement; public endpoints may be intentional.

Evidence: openapi.json:1: pattern matched; source content omitted

Remediation: Verify the intended authorization policy and document it.

Retest: Apply remediation and repeat this check; manually verify the affected workflow.

Related evidence: NIST CSF 2.0 / ID.RA-01